Computer Security research proposal

Beyond Detection Accuracy

Evaluating the reliability, robustness and complementarity of LLMs and static analysis tools for source code vulnerability detection

Software Security + Artificial Intelligence · Draft for supervisor review

Can an LLM be trusted as a security-analysis tool?

False positive

Flags a vulnerability in secure code. Wastes analyst time.

False negative

Misses a real vulnerability. The weakness ships in software.

We study how often each occurs, for which CWE classes, and whether combining an LLM with SAST (Semgrep, CodeQL) reduces them.

Four candidate research gaps

Category reliability

Does performance vary across CWE categories, such as SQL injection vs. path traversal?

Prediction stability

Is the verdict the same across repeated runs, reworded prompts and minor code changes?

Vulnerable vs. patched

Can a model tell a vulnerable function from its slightly different patched twin?

Complementarity

Do LLMs and SAST tools find different vulnerabilities, so combining them helps?

Candidate gaps: the literature review decides which stay open.

Six-step approach, three configurations

01
Collect data
Vulnerable and secure samples

02
Ground truth
Verify labels, CWEs, patched pairs

03
Select tools
3 LLMs, Semgrep and CodeQL

04
Run experiments
2–3 prompts, 3–5 repeats each

05
Evaluate
Compare with verified labels

06
Analyze
Per tool, per CWE, hybrid test

LLM-only

SAST-only

Hybrid: SAST warning + code context, LLM judges

Data and evaluation

Data

- 500–1,000 samples, balanced vulnerable and secure
- 4–6 CWE categories, one language to start (Python or C/C++)
- PrimeVul as main source, Juliet subset, Devign optional
- Patched pairs, de-duplication, manual label audit

Evaluation

- Precision, recall, F1, false-positive and false-negative rates
- Consistency across repeated runs
- Per-CWE results and pair discrimination
- Robustness, complementarity, qualitative error review

Limitation noted: possible training-data leakage from public benchmarks.

Contributions, team and risks

Contributions

- LLM reliability assessment
- False-positive and false-negative analysis
- Per-category performance
- Stability across runs and prompts
- Hybrid LLM + SAST evaluation

Main risks

- API cost: small, fixed scope
- Mislabeled or leaked data: audits and patched pairs
- Model updates: record versions and run dates

Team of five

- Literature and datasets
- Preprocessing and labels
- LLM and prompt experiments
- SAST and hybrid detection
- Metrics and visualization